Blast.fun Security Assessment

Prepared by: GiveRep Labs

Eason Chen

Report issued: November 6, 2026

Assessment period: November 3 to 5, 2026

Reviewed revisions:

`850d8227...`, `8c04789d...`, `b50d0c3b...`

Remediation reviewed: `af0765da...`

Contents

1 Executive summary **2**

2 Project overview **2**

3 Assessment scope and revisions **2**

3.1 Packages reviewed 2

3.2 Revision table 3

3.3 Out of scope 3

4 Methodology **3**

5 Results summary **3**

6 Findings **4**

6.1 Confirmed vulnerabilities 4

6.2 Low findings 4

6.2.1 LOW-01: the coin `TreasuryCap` is released to the publisher before venue preparation and may allow Cetus pool pre-creation 4

6.2.2 LOW-02: permissionless auto-LP compounding has no price bound 5

6.2.3 LOW-03: LP custody is no-exposed-withdrawal, not permanent, through an upgradeable migrators package 6

6.2.4 LOW-04: permissionless settle and cancel of an ignored funded presale . . . 6

6.2.5 LOW-05: a proposal can collapse future notice to zero 6

6.3 Informational observations 7

6.4 Maintainer-reported issue 8

6.4.1 REP-01: repeated `vault::share_with_position` calls 8

6.5 Refuted candidates 8

6.6 Unverified hypotheses 9

7 Test scope **9**

8 Trusted dependencies and administrative assumptions **10**

9 Revision and remediation history **10**

10 Limitations **11**

11 Appendix: source references **12**

1 Executive summary

No confirmed security vulnerabilities were identified in the reviewed scope.

GiveRep reviewed the Blast.fun launchpad, presale, migrators, admin, vault, and core packages, including the refactor and its follow-up changes. The assessment covered access control, upgrades, asset custody, pricing, fees, migration, and holder rewards. The liquid-staking source was also compared with issues reported in audits of other Sui liquid-staking protocols.

The report records five Low findings and fifteen informational observations, with no Critical, High, or Medium finding established. The project addressed GiveRep's TreasuryCap custody and auto-LP compounding findings. The maintainer-reported vault initialization issue was also addressed. The remaining Low observations concern upgrade authority, presale cancellation, and administrative notice.

GiveRep reviewed the remediation changes through `af0765da` and ran the relevant regressions. The findings retain their original descriptions and severities, with their current remediation status recorded below. The follow-up covers the fixes and affected code, rather than a new full assessment of every package.

The liquid-staking package (`blast_sui`) does not compile at the frozen revision and is out of scope for a security assurance; its current deployment and any live value remain unknown.

2 Project overview

Blast.fun is a Sui launch protocol in two parts. A launchpad (`blast_fun`) lets creators launch a new coin (the Meme) on a constant-product bonding curve priced in an admitted Quote coin. A presale (`blast_presale`) runs an escrowed presale with fee and creation policies. Both products hand their liquidity to an admitted migration adapter (`blast_migrators`), which seeds a DEX pool on Cetus or Bluefin. A shared vault (`blast_vault`) holds LP custody, holder rewards, and auto-LP and buyback accounting. Shared administration (`blast_admin`) and shared arithmetic and treasury primitives (`blast_core`) sit underneath.

The refactor under review consolidated these packages and their dependency closure into one stack, and introduced a sealed treasury-cap design (ADR 0138) that changes how the generated coin's mint authority is held between publication and venue preparation.

3 Assessment scope and revisions

3.1 Packages reviewed

Package	Contents reviewed
`blast_admin`	ACL, delayed-action primitives, `PackageAdmin` / `PackageVersion`
`blast_core`	Basis-point arithmetic, apportionment, payout and vesting, fee split, protocol-fee ledger, treasury, Merkle, migration hand-off, owner proof, sealed treasury cap
`blast_vault`	LP custody, fee split, Blast share, partner hold, holder rewards, auto-LP and buyback, owner claims
`blast_migrators`	Cetus and Bluefin venue adapters
`blast_fun` (launchpad)	Bonding-curve launchpad, launch ticket, allocation and fees
`blast_presale`	Escrow presale, fee policy, creation policy, migration hand-off

Package	Contents reviewed

The dependency closure was also read where it touches the six packages: `blast_partners`, `blast_fun_vesting`, `blast_fun_otc`, `launch_ticket_template`, `presale_coin_template`, `coin_template`, and the vendored Aftermath DAO presale adapter.

3.2 Revision table

Revision	Role in this assessment	Source reviewed
`850d8227edce340a6d5d839d30efbd14b707dfc6`	Previous version (before the refactor), comparison baseline	Yes
`8c04789d3f9a8606944717841071a5fe8e4e10d1`	Refactor under primary review	Yes
`b50d0c3bee50b637a673d1ccb64b5413af4ba518`	Incremental follow-up (rename-and-clarify plus ADR 0138 sealed cap)	Yes
`af0765dab18de741b130c52831c859717134f2c1`	Targeted remediation review of fixes and affected callers	Yes

The full assessment covers the versions above through `b50d0c3b`. The subsequent remediation review covers changes through `af0765da`, including the venue-binding change at `d80f2834`. It does not establish that a deployed package matches those sources.

3.3 Out of scope

The `blast_sui` liquid-staking package (13 modules, about 2,700 source lines) was inventoried, statically reviewed against known liquid-staking vulnerability classes, and compared with public audit reports of comparable products, but it is not covered by this assessment for a security assurance. It does not compile at the frozen revision (`b50d0c3b`), and its current deployment and any live value are unknown. Off-chain services, key custody, front-end components, and infrastructure are also out of scope.

4 Methodology

The assessment combined source review of the six packages and their dependency closure with disassembly of pinned mainnet Cetus (v15) and Bluefin (v17) venue bytecode, offline simulation against the project's pinned toolchain (Sui 1.77.2, Move framework `06734f6f`) using deterministic fixture keys and fictitious balances under a network-denied sandbox, and arithmetic analysis of the economic paths: the bonding curve, apportionment, rounding, supply transitions, and fee and reward accounting. Findings were checked against the repository's decision records and tests, and against public audit reports of comparable Sui liquid-staking and concentrated-liquidity products.

Severity reflects the potential impact and the authority needed to trigger the behaviour. Security findings, administrative trust assumptions, and unresolved reports are listed separately.

5 Results summary

Severity	Assessed items
Critical	0
High	0
Medium	0
Low	5
Informational	15

The five Low findings are: one potential-authority finding identified by GiveRep and fixed by the project in response (LOW-01), one inherited and still-open observation (LOW-02), and three trust or operational observations with explicit prerequisites that exclude an arbitrary attacker (LOW-03, LOW-04, LOW-05). One maintainer-reported vault issue has been addressed (section 6.4). LOW-01 and LOW-02 are resolved; LOW-03 is clarified in documentation, while LOW-04 and LOW-05 retain their design and administrative assumptions. Refuted candidates and unverified hypotheses are listed separately and do not count as findings.

6 Findings

6.1 Confirmed vulnerabilities

None. No confirmed security vulnerability of Critical, High, or Medium severity was identified in the reviewed scope.

6.2 Low findings

6.2.1 LOW-01: the coin `TreasuryCap` is released to the publisher before venue preparation and may allow Cetus pool pre-creation

Severity

Low

Status

Resolved (identified by GiveRep; the project fixed it in response)

Affected code

`sui/launch_ticket_template/sources/meme.move` at `8c04789d` (ticket and `TreasuryCap` transferred to the publisher) and `sui/launchpad/sources/launch/launch_ticket.move` at `b50d0c3b` (fixed)

Permalinks

https://github.com/interest-protocol/blast-v2-contracts/blob/8c04789d3f9a8606944717841071a5fe8e4e10d1/sui/launch_ticket_template/sources/meme.move#L55-L56
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/launchpad/sources/launch/launch_ticket.move#L41

In the previous version the generated coin's `TreasuryCap` was sealed inside the `LaunchTicket` and only lent out through a witness-gated accessor. The refactor changed this so the ticket template transfers both the ticket and the raw `TreasuryCap` to the publisher at publication. The publisher therefore holds mint and burn authority for the interval between coin publication and venue preparation.

GiveRep investigated this as a possible economic denial of service: a malicious publisher could

mint Meme, pre-create the Cetus pool for the pair the launch will later reserve, then let the launch graduate onto a pool migration cannot create again. The specific "strand buyers" chain is currently blocked, for a reason the maintainer identified and this review reproduced in a native test: `launch_ticket::destroy` asserts that the circulating supply equals the atomic supply exactly, Cetus rounds liquidity removal down so one atom stays locked in the pool, and `finalize` therefore aborts before any buyer enters. The protection is incidental, resting on Cetus rounding rather than on custody.

Keeping the capability sealed removes the pre-preparation window without relying on Cetus rounding. The project addressed this finding: ADR 0138 introduces a `SealedTreasuryCap` that leaves the ticket only as a sealed value an admitted venue may borrow for pool preparation and only the product may open, merged at `b50d0c3b`. The seal is the fix for the custody issue; the supply check had already blocked the proposed buyer-fund lock.

Preconditions: a malicious publisher, between publication and venue preparation.

Root cause: the refactor moved mint and burn custody out of the launch ticket and into the publisher's hands for a bounded window.

Impact: potential pool pre-creation and launch disruption; the specific fund-freeze chain is blocked by the exact-supply check.

Recommendation: keep the coin's mint authority sealed until the venue has prepared the pool. Implemented.

Remediation status: resolved at `b50d0c3bee50b637a673d1ccb64b5413af4ba518`.

6.2.2 LOW-02: permissionless auto-LP compounding has no price bound

Severity
Low

Status
Resolved at `af0765da` (identified by GiveRep; the project fixed it in response)

Affected code
Cetus and Bluefin `compound_auto_lp` at `b50d0c3b`

Fix https://github.com/interest-protocol/blast-v2-contracts/commit/af0765dab18de741b130c52831c859717134f2c1

The earlier public entrypoints reinvested waiting auto-LP fee balances at the pool's current price, without a price bound. A caller could influence the execution price around compounding. Exposure was limited to the auto-LP share of collected fees, rather than migration principal; a profitable attack sequence was not established in the original assessment.

The project replaced those entrypoints with private entries that require a live `AutoLpAdmin` capability and inclusive minimum and maximum sqrt-price bounds. Both venues check the pool identity, validate the bounds and reject a current price outside them before taking vault balances. Fee collection remains permissionless and separate from compounding.

The updated native tests pass for authorized execution, role revocation, invalid or excluded price bounds, wrong pools, rollback when an earlier swap invalidates the bounds, and later reuse of a consumed pool input. The entries consume and re-share the pool; this does not prevent earlier swaps or price changes across transactions. Protection depends on authorization and meaningful price bounds together.

Remaining assumption: the authorized keeper must derive suitably narrow bounds from a trusted reference, in the pool's actual coin order. The contracts do not supply an independent oracle or validate quote freshness.

6.2.3 LOW-03: LP custody is no-exposed-withdrawal, not permanent, through an upgradeable migrators package

Severity
Low

Status
Documentation clarified at `af0765da`; upgrade trust remains

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/vault/sources/vault.move#L215

`vault::position_mut` and `vault::auto_lp_position_mut` lend a mutable `Position` to venue code, and the `blast_migrators` package is upgradeable with no `make_immutable` wrapper. A compatible migrators upgrade (48-hour delay under `UpgradeAdmin`) could withdraw Bluefin migration principal or Cetus auto-LP principal. This is a trust boundary, not an arbitrary-attacker path: it requires the migrators upgrade-admin role and a 48-hour wait. The repository's own dependency notes describe the principal as held by an upgradeable package with no exposed withdrawal path. The project corrected the vault comments at `af0765da` to describe that boundary explicitly. This is a documentation clarification, not a change to immutable custody.

Preconditions: hold the migrators `UpgradeAdmin` role and wait the 48-hour delay. **Recommendation:** reconcile the vault documentation, or wrap the migrators package with `make_immutable` once it is stable.

6.2.4 LOW-04: permissionless settle and cancel of an ignored funded presale

Severity
Low

Status
Open (documented)

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/presale/sources/blast_presale.move#L851

A funded presale that nobody settles for its whole liquidity window can be settled and cancelled by anyone in one programmable transaction at the window deadline, cancelling the sale (full refunds, creator tokens locked). This is documented in the presale constants and requires a week of total inaction by every interested party; there is no theft.

Preconditions: a full week of inaction by the creator and all participants. **Recommendation:** none required; the behaviour is documented. Confirm the operator is aware of the window.

6.2.5 LOW-05: a proposal can collapse future notice to zero

Severity
Low

Status
Open (administrative trust, by design)

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/admin/sources/delayed/delayed.move#L103

`Delayed::schedule(value, next_delay=0)` lets the owning role zero all future notice after one

applied wait, because the applied delay is always the wait even when the proposed next delay is zero. This applies to the treasury destination, trade and creation fees, the LP-fee share, upgrade delay, and the holder-round delay. It is reachable only by the role that owns each setting.

Preconditions: hold the relevant admin role. **Recommendation:** if any of these slots is meant to carry a notice control, enforce a minimum delay for that slot.

6.3 Informational observations

These are documentation, test-coverage, and design observations, none of which is a vulnerability.

ID	Area	Observation
INFO-01	Test coverage	The address-dependent `creator_authority` fixtures now support the committed `0x0` and harness `0xc` addresses. All 19 tests pass at both addresses. Resolved at `af0765da`; production signature validation is unchanged.
INFO-02	API surface	The seal's borrow surface exposes full mint and burn authority to admitted venues during prepare (`sealed_treasury_cap::treasury_cap_mut` returns `&mut TreasuryCap`). The only borrower uses it to mint a one-per-type pool-creation cap. Trust/API-surface observation.
INFO-03	Economics	`join_opening_round` uses unchecked u64 addition (self-denial only, requires a Quote near `u64::MAX` atoms).
INFO-04	Design	Launch finalization now rejects allocation-derived LP prices outside the seedable range. The added rejection test passes. The missing guard is resolved at `af0765da`; a general cancellation path from `MigrationReady` was not added.
INFO-05	API surface	`sealed_treasury_cap::new` is public for any witness, so a `SealedTreasuryCap` object is not by itself proof of product sealing.
INFO-06	API surface	`migration::redeem_ticket` is public; a creator can discard the ticket and consume the type's single creation-cap slot (self-griefing only).
INFO-07	Tooling	The obsolete raw-cap token constructors were removed at `af0765da`, and documentation directs users to the sealed-cap presale coin template. The remaining faucet and template tests pass. This retires the obsolete API rather than restoring it.
INFO-08	Design	Protocol-share application is not settle-first, unlike fee-split application (documented asymmetry).
INFO-09	API surface	`blast_presale::destroy_cap` lacks an `assert_current` generation check (harmless).
INFO-10	Test coverage	The freshly rebuilt `af0765da` native venue suite passes 11/11. The earlier sealed-cap setup failure was not reproduced. Current execution coverage is restored; no separate source repair to that fixture lookup is attributed to the project.
INFO-11	Liquid staking	`blast_sui` does not compile at `b50d0c3b`; it still imports `blast_admin::operational_version` and `blast_admin::upgrade_custody`, which were deleted in the admin fold. A real source defect.

ID	Area	Observation
INFO-12	Liquid staking	`boosts/aftermath_adapter` shares the same stale-admin-module compile break as INFO-11.
INFO-13	Liquid staking	Single-validator concentration plus a "rates never decrease" assumption: a sole-validator slash would make near-full redemptions fail closed until a rescue upgrade. Documented design.
INFO-14	Liquid staking	Fee admin sets the redemption fee (capped at 100 bps) with no delay; upgrade-authority delay lived in modules deleted by the admin fold and is not verifiable from the frozen tree.
INFO-15	Liquid staking	Near-full redemption is fail-closed at or below 3 MIST, a bounded rounding artifact, not a fund-conservation defect.

The liquid-staking observations (INFO-11 through INFO-15) come from a static review of the 13 `blast_sui` modules plus an arithmetic model and a historical diagnostic build. No current native `blast_sui` test coverage was produced, because the package does not compile at the frozen revision. A compatible project-local toolchain (Sui 1.77.2 with the pinned Move framework) is available, so native coverage is achievable once the compile break is fixed; it was not produced for this assessment.

6.4 Maintainer-reported issue

6.4.1 REP-01: repeated `vault::share_with_position` calls

Reported by
The project maintainer

Status
Resolved at `d80f2834`; remediation reviewed through `af0765da`

Code
https://github.com/interest-protocol/blast-v2-contracts/blob/af0765dab18de741b130c52831c859717134f2c1/sui/vault/sources/vault.move#L125-L223

The maintainer reported that repeated vault-sharing calls could attach unrelated position objects and emit additional `VaultCreated` events. Shared-object input rules do not themselves prevent by-value consumption and re-sharing.

The project now records the constructing venue's original type in the vault and checks that type before attaching a position or emitting the creation event. An attacker-defined venue is rejected with `EWrongVenue`; a repeated attachment under the bound venue encounters the existing position key. Five added Move regressions and the native rogue-venue test pass. The native test uses a valid shared vault input and checks that rejection leaves no committed objects or events and preserves the vault contents. This issue was reported by the maintainer, not discovered by GiveRep.

6.5 Refuted candidates

The following proposed failure paths did not establish a security finding.

- **REF-01: Cetus pool pre-creation strands a graduated launch's buyers.** Refuted as a working exploit. The exact-supply check plus Cetus round-down removal leave the launch unopenable, so no buyer funds are stranded. The underlying custody change is retained as LOW-01.

- **REF-02: `close_round` is unreachable, permanently locking unclaimed holder rewards.** The premise is refuted: a shared object cannot be passed as an owned/immutable argument, but it can be consumed by value as a shared-object argument. A fresh native probe confirms the consume-by-value path. End-to-end recovery assertions were not reached by the earlier `b50d0c3b` run because setup failed. The rebuilt `af0765da` venue suite now passes, including holder-reward close and recovery. No Medium finding follows.
- **REF-03: Bluefin pool duplication blocks migration.** Refuted. Disassembly of the pinned Bluefin pool bytecode shows pool creation does not enforce one pool per type pair and tier, so the migration's own creation always succeeds.
- **REF-04: Bluefin pool uniqueness lets a buyer brick migration.** Refuted on the same evidence as REF-03.
- **REF-05: opening-round delivery lacks a last-claim remainder sweep.** Refuted: the shrinking-denominator pro-rata drains both pots to zero; only order-dependence of at most one atom remains.

6.6 Unverified hypotheses

- **UNV-01: Cetus delisting or pre-creation makes a launchpad migration abort forever.** Not established. This depends on a privileged Cetus operator action (delisting a fee tier or pre-creating the pool at the registered spacing), not an arbitrary caller, and it was not reproduced. It remains an open residual-risk hypothesis, not a confirmed finding.

7 Test scope

The remediation review exercised the source at `af0765da` with Sui 1.77.2 and the pinned Move framework. No production source, named addresses or assertions were changed to obtain these results.

Move suite	Passed / selected
`blast_admin`	198 / 198
`blast_core`	85 / 85
`blast_vault`	127 / 127
`blast_fun` (launchpad)	449 / 449
`blast_presale`	287 / 287
`blast_migrators`	40 / 40
`blast_partners`	74 / 74
`blast_presale_testkit`	2 / 2
`blast_fun_vesting`	53 / 53
Presale coin template	1 / 1
Aftermath DAO presale adapter	17 / 17
Total distinct Move tests	**1,333 / 1,333**

At the initial 10-million-instruction limit, six launchpad, twelve presale, one migrators and one partners test exhausted their budgets. Those suites pass with higher instruction limits: ten billion for launchpad and one billion for the others. These are separate command configurations, not changes to the tested contracts. The 19 creator-authority tests also pass at the supported `0xc` fixture address; repeated address runs are not added to the distinct-test total.

The native PTB targets were rebuilt from the remediation source and executed:

Native target	Passed / selected
`venue_fork`	11 / 11
`presale_venue_fork`	11 / 11
`atomic_migration`	12 / 12
`bootstrap`	1 / 1
Total	**35 / 35**

The venue tests cover auto-LP authorization, price bounds, role revocation, wrong-pool rejection, rollback after an earlier swap invalidates the bounds, and later reuse of the consumed pool input. The rogue-venue test exercises the vault-sharing fix using a valid shared-object input. The lifecycle tests include migration, holder-reward claim and close recovery, and relevant rollback and upgrade paths. The earlier `b50d0c3b` venue setup failure was not reproduced in this rebuilt suite.

An earlier dedicated reproduction of the proposed TreasuryCap pool-precreation attack covered two Cetus coin orderings and two seed sizes. Withdrawal left one atom of each coin in the pool, and the exact-supply check rejected launch finalization. That historical result is separate from the remediation regression totals above.

All transaction execution used offline simulation with deterministic fixture keys and fictitious balances. Venue bytecode came from the committed mainnet snapshot at checkpoint 339033808, with framework linkage adapted to the simulator; this is not current-mainnet replay. `blast_sui` and `boosts/aftermath_adapter` still fail compilation on stale administration APIs, so no passing test coverage is claimed for those packages.

8 Trusted dependencies and administrative assumptions

The assessment relies on the following components and administrative controls.

- The `blast_admin` ACL issues a role's witness only to a live `AdminCap` holding that role, and delays root transfers.
- `blast_partners` pays a partner at most its share of Blast's fee (capped at 80%) and enforces removal notice periods.
- The Sui framework and the Move standard library are trusted for `Balance`/`Coin` conservation, the coin registry supply modes, dynamic fields, package upgrade tickets, Ed25519 verification, type identity, and checked arithmetic.
- The Cetus and Bluefin venues are trusted for their documented pool-creation and liquidity-removal behaviour, resolved from pinned mainnet bytecode and, for the Cetus path, exercised in simulation.
- Root and role authority is trusted. The `SuperAdminCap` grant and `UpgradeAdmin` scheduling are stated trust assumptions, not attacker-reachable surfaces. Custody of the root and upgrade roles is assumed to follow the project's documented multisig plan.

9 Revision and remediation history

GiveRep reviewed the changes from `b50d0c3b` through `af0765da`, including the affected production code, callers and relevant regressions. The table distinguishes implemented fixes from documentation changes and retained design assumptions.

Item	Project response	Result
LOW-01	GiveRep identified the pre-preparation mint-authority exposure; the project introduced the ADR 0138 sealed cap at `b50d0c3b`.	Resolved; sealed custody remains present in the latest reviewed source.
LOW-02	GiveRep identified the auto-LP exposure; the project added authorization and keeper-approved price bounds at `af0765da`.	Resolved in reviewed source; both venue paths pass the native regressions.
LOW-03	Custody wording at `af0765da` now distinguishes an absent withdrawal entrypoint from immutable custody.	Documentation clarified; upgrade-authority trust remains.
LOW-04/05	Inactivity cancellation and administrative notice policy are unchanged.	Retained design and trust observations.
REP-01	The maintainer's reported sharing issue was addressed with a bound venue type at `d80f2834`.	Resolved; Move and native rogue-venue regressions pass.
INFO-01	Address-specific signature fixtures were corrected at `af0765da`.	All 19 tests pass at both supported addresses.
INFO-04	Launch finalization checks the allocation-derived LP price at `af0765da`.	Missing seed-price validation resolved; no general cancellation path added.
INFO-07	Obsolete raw-cap tooling was retired at `af0765da`; the supported template flow is documented.	Faucet and template tests pass.
INFO-10	A fresh rebuild exercises the latest venue source.	Current suite passes 11/11; historical setup failure not reproduced.
INFO-11/12	No corresponding source repair in this interval.	Compilation remains blocked by stale administration APIs.

Other observations retain their stated assessment unless a change is identified above. Historical findings and their discovery attribution remain in the report after remediation.

Revision	Role
`850d8227edce340a6d5d839d30efbd14b707dfc6`	Previous version before the refactor
`8c04789d3f9a8606944717841071a5fe8e4e10d1`	Primary refactor assessment
`b50d0c3bee50b637a673d1ccb64b5413af4ba518`	Sealed TreasuryCap and incremental assessment
`d80f2834468ba798df66f36d01fd64eec9d4df91`	Vault venue binding and UID-backed origin changes
`af0765dab18de741b130c52831c859717134f2c1`	Latest source covered by the targeted remediation review

10 Limitations

- The full assessment covers the stated revisions through `b50d0c3b`. The follow-up through `af0765da` covers remediation changes and affected code, not a fresh full audit or a live

assessment of deployed packages.

- Deployment parity, whether the deployed packages match the reviewed revision, was not established from on-chain data, and no live value-at-risk quantification was performed.
- The `blast_sui` liquid-staking package does not compile at the frozen revision, its upgrade policy lives in modules deleted before the frozen head, and its current deployment and any live value are unknown. The absence of a deployment record and the compile break do not establish that no live `blast_sui` value exists.
- Comparison with public audits of comparable liquid-staking products is reference material only; similarity does not establish the absence of all risk in `blast_sui`.

The conclusions apply to the revisions and tests described in this report. They are not a certification of the currently deployed system.

11 Appendix: source references

Related security assessments:

- Asymptotic, Blast Launchpad security report (October 2026). https://raw.githubusercontent.com/interest-protocol/blast-v2-contracts/850d8227edce340a6d5d839d30efbd14b707dfc6/audits/blast-launchpad-asymptotic-oct-2026.pdf
- OtterSec, Cetus CLMM security assessment (June 6, 2025). https://raw.githubusercontent.com/CetusProtocol/Audit/e6cde26e7505281af6c7a3167fc4b18c54b85f6c/01-clmm/reports/Jun%202025-CLMM%20Audit%20by%20OtterSec.pdf
- Zellic, CetusProtocol smart contract security assessment (April 11, 2025). https://raw.githubusercontent.com/CetusProtocol/Audit/e6cde26e7505281af6c7a3167fc4b18c54b85f6c/01-clmm/reports/Apr%202025-CLMM%20Audit%20by%20Zellic.pdf

Liquid-staking reference corpus: ten public audit reports and 28 finding records covering SpringSui, Aftermath, Volo, Haedal, and Suilend. One entry is an adjacent lending-vault report, not a core liquid-staking report. These are reference and analogy material only.

Reviewed source: `interest-protocol/blast-v2-contracts` at the revisions in section 3.2.